

2025

GUIDE DE CONFORMITÉ DU RGPD POUR UNE PME INDUSTRIELLE

CNIL ■
COMMISSION NATIONALE
INFORMATIQUE & LIBERTÉS

Réalisé par :

Constant AUDIBERT
Paul BABIN
Rafaël BRUNET-LARE
Théo GARDERE
Orion GIRAUD

La protection des données personnelles est un enjeu majeur pour toutes les entités qui réalisent des traitements de données. La société industrielle, qui emploie 100 salariés, traite une grande quantité de données sensibles au sein de son service Ressources Humaines sans respecter pleinement le RGPD, en vigueur depuis mai 2018. Le RGPD impose, dans certains cas (pas le nôtre mais il est quand même recommandé d'en désigner un), la nomination d'un Délégué à la Protection des Données (DPO), chargé de veiller à la conformité et de tenir le registre des traitements. Cette désignation doit être formalisée rapidement et déclarée à la CNIL.

Ce rapport, rédigé en tant que DPO, a pour objectif d'identifier les manquements, d'analyser les risques et de proposer un plan d'action structuré. Il se concentre sur trois axes principaux : Nous commencerons tout d'abord par évoquer l'élimination des données potentiellement interdites ou non pertinentes. Ensuite, nous continuerons par traiter la création et la tenue du registre des traitements. Enfin, nous terminerons par la mise en place des mesures de sécurité et de conformité.

Élimination des données interdites et non pertinentes

Le principe fondamental de minimisation des données impose que seules les informations nécessaires à la gestion du personnel soient collectées et conservées. Nous nous devons d'analyser toutes les données déjà présentes dans la base et de se demander si nous pouvons les conserver.

Certaines données actuellement présentes dans les bases ne sont pas indispensables. Ces informations dépassent le strict besoin professionnel et ne doivent pas être collectées sauf justification légitime et documentée.

- Profession des parents de l'employé.
- Nature et lieu des études suivies par les enfants de l'employé.
- Situation matrimoniale détaillée (au-delà de marié, pacsé, célibataire si non indispensable à la paie).
- Références du passeport (sauf salarié étranger nécessitant un titre de séjour).
- Désidératas personnels de carrière (souhaits sans lien avec une évaluation).

Leur conservation viole le principe de minimisation donc on se doit donc de les supprimer ou de les anonymiser.

D'autres données sont considérées comme sensibles et doivent être particulièrement protégées. Ces informations sont encadrées par l'article 9 du RGPD. Leur traitement nécessite un fondement spécifique, des mesures de sécurité avancées (accès restreint, chiffrement) et parfois une autorisation explicite. Ces données sont à protéger de manière renforcée :

- Données de santé : aptitude médicale, pathologies connues, propositions du médecin du travail.
- Données relatives à la reconnaissance de la qualité de travailleur handicapé (RQTH).
- Appartenance syndicale (si connue dans le cadre de la gestion RH).
- Participation aux grèves (nombre de jours de grève suivis).

- Sanctions disciplinaires.
- Données issues du titre de travail pour salariés étrangers (copie, numéro, validité).

Un nettoyage immédiat des bases de données doit donc être réalisé. Toutes les données sensibles comme les affiliations syndicales, les informations médicales trop détaillées, ou encore les photos et informations non essentielles, doivent être réétudié pour en juger de leur utilité. De plus, certaines données collectées qui ne sont pas pertinentes par rapport aux finalités déclarées doivent également être retirées pour garantir la conformité avec le cadre légal.

Création et tenue du registre des traitements

Le registre des traitements est un outil essentiel pour garantir la transparence et le suivi des données personnelles dans l'entreprise ([voir modèle excel](#) en annexe). Même si notre société compte moins de 250 salariés, et que la loi n'exige pas de consigner toutes les données, il est recommandé de toutes les inclure. Cela permet de se préparer à une éventuelle croissance de l'entreprise et de faciliter la conformité à long terme. Le registre doit également indiquer le nom du DPO (Délégué à la Protection des Données), qui est chargé de superviser et de contrôler les traitements.

Ce registre doit décrire chaque opération de traitement, en précisant les objectifs, les types de données concernées, les bénéficiaires et la durée de conservation. Il peut s'agir de l'élaboration de nouvelles politiques internes, de la formation des employés, de l'adoption de nouvelles technologies ou de toute autre action visant à respecter la loi et à protéger les données personnelles. Cette démarche est particulièrement importante pour le département des ressources humaines, qui manipule des informations sensibles sur les employés.

Il est conseillé de commencer par un récapitulatif des différentes activités de traitement menées par l'entreprise, incluant les données des clients, des employés ou d'autres catégories de données. Le registre doit aussi documenter toutes les interactions avec des parties externes, comme les demandes des individus concernant leurs droits (accès, rectification, suppression), les échanges avec l'APD ou d'autres autorités, et les communications avec les prestataires. Toute violation de données doit être consignée avec les mesures correctives mises en place. La tenue de ce registre constitue ainsi une preuve concrète de l'engagement de l'entreprise à gérer les données personnelles de façon responsable et conforme au RGPD.

Mise en place des mesures de sécurité et de conformité

La protection des données personnelles repose à la fois sur des mesures techniques et organisationnelles. D'un point de vue technique, il est essentiel de renforcer les contrôles d'accès en attribuant à chaque employé un identifiant unique et un mot de passe solide, de programmer des sauvegardes régulières et de garantir un archivage sécurisé des données sensibles. Il est également recommandé d'installer un système de traçabilité pour suivre les accès aux fichiers confidentiels.

Du côté organisationnel, il est important de mettre en place une politique claire sur la gestion des droits d'accès et le suivi des consultations, ainsi que sur la formation et la sensibilisation des employés aux bonnes pratiques de sécurité et aux obligations RGPD. Les employés doivent être informés sur les données collectées, leur utilité, leurs droits et les procédures pour

les exercer. Cette information doit être incluse dans une notice remise dès le recrutement, accompagnée d'un formulaire de consentement lorsque nécessaire.

En résumé, les mesures principales à appliquer sont : restreindre strictement les accès aux seuls RH et personnes autorisées, mettre en place des sauvegardes régulières et sécurisées, et assurer la traçabilité des accès aux données sensibles.

Par ailleurs, il est important de respecter les réglementations nationales et internationales relatives à la sécurité et à la santé au travail. La norme ISO 45001, qui reprend certaines exigences de l'OHSAS 18001, définit les bonnes pratiques en matière d'hygiène, sécurité et environnement. En France, le Code du travail stipule à l'article L.4121-1 que l'employeur doit prendre toutes les mesures nécessaires pour assurer la sécurité et protéger la santé des salariés. Proposer, par exemple, des formations continues en réalité virtuelle aux employés est un moyen efficace de rester conforme à ces obligations.

En conclusion, nous pouvons donc affirmer qu'il y a plusieurs aspects importants pour se conformer aux principes du RGPD sous peine de risques juridiques et financiers importants, avec des sanctions pouvant atteindre jusqu'à 20 millions d'euros ou 4 % du chiffre d'affaires annuel mondial pour des violations majeures, ainsi que des amendes pénales sévères. Pour y remédier, les actions prioritaires consistent à supprimer immédiatement les données non conformes, à désigner un DPO compétent, à créer un registre des traitements complet, et à renforcer les mesures de sécurité. Pour finir, la conformité du RGPD doit être considérée comme un processus dynamique, qui nécessite une veille continue et des adaptations régulières pour faire face aux évolutions réglementaires et technologiques.